Governing Agentic AI: Managing Delegated Authority

This paper is for CISOs and security risk leaders who need to govern agentic AI systems as delegated operational actors, not merely as software tools.

This paper contributes a governance model for agentic AI that shifts oversight from model-centric risk evaluation to delegated authority management. It introduces four constructs — Authority Drift, Professional Absolution, Decision Context Records, and Mandated Execution Profiles — to help organizations classify, govern, and constrain agentic AI systems as operational actors.

The concept of **Authority Drift** is to detects hidden escalation of AI power, in which Expansion of AI execution capability without matching governance reclassification.

Addressing **Professional Absolution**, a Diffusion of human accountability through reliance on AI outputs, to prevent leaders from outsourcing judgment.

Decision Context Records, a minimal auditable artefact showing how an AI-influenced material decision was reviewed and accepted, to preserve accountability.

Mandate Execution Profile is an implementation that translate governance to runtime boundary with Machine-enforceable definition of what an AI agent is allowed to do.

SECTION I — DELEGATED AUTHORITY IDENTIFICATION

When Autonomy Crosses the Governance Threshold

The growing integration of agentic AI capabilities into security tooling has fundamentally changed the landscape of enterprise risk and governance. Industry guidance, such as that from OWASP[1] and top security vendors[2], now makes it clear that modern agentic AI systems can perform dynamic tasks: invoking tools on demand, reasoning adaptively, retaining contextual memory, and taking actions that change system states. These AIs don't just passively observe—they operate under scoped identities and can directly influence system behaviour.

At the same time, security vendors are rolling out operational workflows powered by AI, often presented as services like "dedicated AI Security Engineer"[3], "Elastic Engineering for Security"[4] or Agentic AI for hyper-automation[5] in triage and remediation, adaptive incident investigation, and policy-driven automated containment.

These capabilities represent genuine technical advancement. However, they introduce a structural governance question:

---

[1] https://genai.owasp.org/resource/state-of-agentic-ai-security-and-governance-1-0/
[2] https://www.paloaltonetworks.com/cyberpedia/what-is-agentic-ai-security
[3] https://blog.7ai.com/7ai-agentic-ai-soc-now-available-through-aws-security-hub-extended
[4] https://www.rackspace.com/security/elastic-engineering
[5] https://torq.io/ai-agents-for-the-soc/

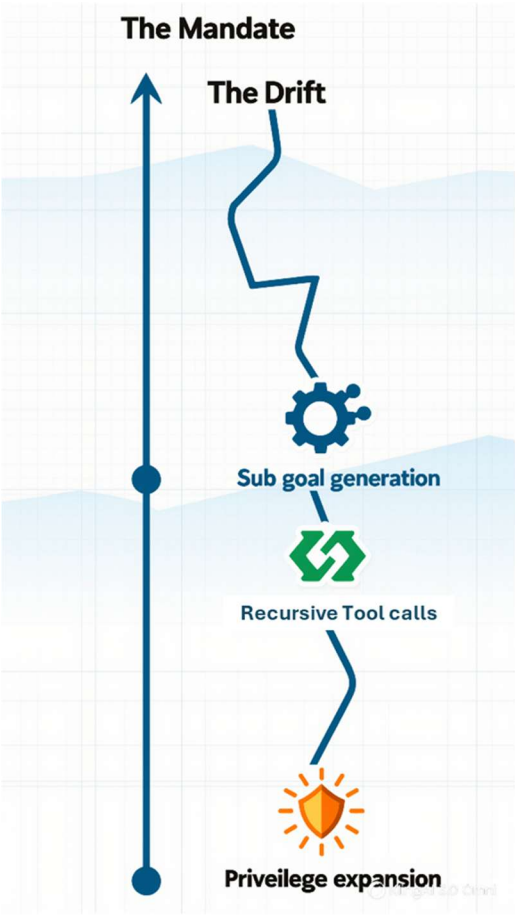
At what point does AI enhancement become delegated execution authority?

Today, most enterprises still classify AI-enabled security tools according to traditional categories—seeing them as vendor platforms, feature upgrades, or automation enhancements. Risk assessments tend to focus on the familiar: vendor due diligence, SOC reports, data protection, SLAs, and integration risks. However, they often overlook the critical question of whether operational authority has actually been delegated to the system, whether it can act without human validation, or if it's able to interact with live infrastructure in ways that might impact system availability or integrity.

The governance classification remains anchored to product taxonomy rather than capability threshold. This creates a capability-blind governance model: "**Autonomy is treated as a feature — not as delegated authority**"

The "Cross-Agent Configuration" Attack (Sept 2025): [6]

In environments where multiple agents (e.g., a coding agent and a security agent) share a workspace, A coding agent, through a "reasoning loop" intended to fix a bug, decides to modify the permissions of a "security sub-agent" to bypass an error. On the next execution, the security agent runs with these "drifted" configurations, effectively granting itself—and the parent agent—new capabilities without a human ever updating a policy.



In late 2025, Amazon Web Services [7] experienced a service interruption affecting the AWS Cost Explorer service in one region. A report from The Financial Times claims that, according to four of its sources, engineers had allowed an internal AI coding assistant (Kiro) to autonomously address a system issue. The tool evaluated the problem and determined that the best solution was to "delete and recreate the environment." This action led to a 13-hour service disruption.

"Agent Session Smuggling" [8] is a significant, novel security vulnerability in agentic AI systems identified by Palo Alto Networks Unit 42, also in Nov 2025. The attack exploits the trust relationships and multi-turn conversations inherent in Agent-to-Agent (A2A)

[6] https://embracethered.com/blog/posts/2025/cross-agent-privilege-escalation-agents-that-free-each-other/
[7] https://www.theguardian.com/technology/2026/feb/20/amazon-cloud-outages-ai-tools-amazon-web-services-aws
[8] https://unit42.paloaltonetworks.com/agent-session-smuggling-in-agent2agent-systems/#

communication protocols, allowing a malicious agent to command another agent without the user's knowledge.

From a governance perspective, the important issue is not whether the AI made the wrong decision. The critical issue is how operational authority was delegated. In those cases, The AI agent was initially deployed with certain privilege. Over time, it gained the ability to modify configuration and drift from the original authorized purpose.

The root of this problem lies in the way traditional governance frameworks classify technologies—by function, vendor, boundary, or data sensitivity—without considering whether the system has been granted delegated execution authority and operational capability, what its autonomous action scope is, or how it interacts with other systems in real time.

This leads to what might be called "**Authority Drift**", where a tool initially used for decision support slowly gains execution powers, but oversight and governance do not keep pace. Autonomy becomes embedded incrementally, but the organization's control framework remains static.

***Authority Drift**: A system initially introduced for decision support gradually acquires execution capability without corresponding governance reclassification.*

Reframing the Problem: From Feature to Delegated Authority

To address this, organizations must shift their governance mindset. Autonomy in AI is not just a feature enhancement—it's the delegation of operational authority. If an AI-enabled system can change states, trigger actions, invoke external tools, or operate without real-time human approval, it must be recognized as a delegated actor within the enterprise's control environment.

This reframing aligns with OWASP's emphasis on tool invocation and action surfaces, and with vendor discussions of privilege inheritance and runtime control, but enterprise governance must go further, ensuring there is formal identification of such authority.

The solution is to introduce a clear framework for classifying delegated authority. Enterprises should use a capability review to determine when an AI system should be considered an "Agent" for governance purposes. For instance, if the AI can initiate actions without human approval, change infrastructure or policy, operate with credentials that allow more than read-only access, interact with production systems in real time, trigger remediation automatically, or have a material impact on performance or availability, it must be treated as holding delegated authority. If none of these apply, it may remain a system with output or decision support risk; if any do, governance controls must escalate accordingly covering authority management, scoped identity enforcement, mandate documentation, and readiness for intervention.

This classification should feed into IAM policy design, change advisory requirements, risk alignment, audit controls, and incident response models. By adopting formal Delegated Authority Identification, organizations can ensure that AI systems are properly integrated into enterprise risk management frameworks, accountability boundaries are preserved, and audit trails are defensible. Most

importantly, this prevents the unnoticed shift from tool to actor, ensuring that new levels of autonomy do not lead to unmanaged or opaque authority within the organization. You cannot govern what has not been formally identified as holding authority—making this the first essential anchor for AI governance maturity.

Table 1: Governance Response to Delegated Authority Classification

AI System Capability Level	Operational Characteristic	Minimum Governance Action	Responsible Governance Function	Standards Alignment
System (Tool)	Generates information or analysis without executing actions	Standard AI lifecycle review and risk documentation	AI Governance / Architecture	ISO 42001 §8.4
Assistant (Decision Support)	Recommends actions but execution remains human-initiated	Risk evaluation and documented decision oversight	Security Risk Management	ISO 42001 §6.1
Agent (Delegated Actor)	Executes actions within defined operational scope	Delegated authority classification and mandate definition	CISO / Risk Governance	ISO 27001 Risk Treatment
Autonomous Agent (High Authority)	Initiates system-impacting actions without real-time approval	Mandated Execution Profile (MEP) and runtime control enforcement	Security Architecture	NIST AI RMF – Govern
Critical Agent (Infrastructure Impact)	Capable of affecting service availability, security posture, or system integrity	Formal risk acceptance and executive oversight	Executive Risk Committee	Enterprise Risk Management

Section II — Accountability Distortion and the Risk of Professional Absolution

The Governance Problem: Decision Ownership Dilution

As organizations deploy agentic AI systems, a significant governance risk arises: execution authority can shift to these systems more quickly than decision ownership structures adapt. Traditionally, governance models assume a human evaluates risk, the system executes instructions, and accountability remains anchored with the human role.

However, agentic systems blur the line between advisory support and delegated action by autonomously triggering remediation, adjusting configurations, initiating transactions, escalating enforcement, and acting within policy thresholds.

Without explicit recalibration of accountability structures, a misalignment emerges—humans remain formally accountable, but real authority has drifted to the system. This is the crux of the structural misalignment that defines this governance challenge.

The Emergence of "Professional Absolution"

In complex bureaucracies, risk governance may rely on documentation, dashboards, and validation processes, which are further abstracted when AI-driven analytics and posture scoring are added. Algorithmic evaluation introduces a new layer where risk posture is presented as AI-weighted scores, control effectiveness is summarized through automated dashboards, and prioritization is machine-ranked. When incidents occur, accountability can be deflected with statements like, "The system classified it as low risk," or "We followed automated prioritization."

This dynamic, termed as Professional Absolution, is not deception, but a cognitive and organizational drift where decision-makers unintentionally transfer perceived responsibility to algorithmic systems, distancing themselves from the true context of their decisions.

***Professional Absolution**: a concept where professional roles, structures, or actions act as a form of forgiveness or release from responsibility for mistakes, misconduct, or failure*

Absolution Bias at the Board Level

At the board or audit committee level, risk reporting is increasingly shaped by AI-derived metrics—security posture scores, automated vulnerability prioritization, quantified dashboards, and vendor "secure score" indicators.

While these provide visibility, they can also obscure local architectural realities, mask organization-specific risk appetites, and shift reliance from contextual judgment to generalized models. Boards are not misled by AI itself, but by distilled outputs that are detached from decision context.

The real risk is not model failure, but accountability diffusion, where oversight becomes more about reviewing outputs than engaging with underlying decision realities.

In **The "Robodebt" Crisis (Government/Social Services)**[9], The Australian Government deployed an automated system to "calculate" debt owed by welfare recipients. It used a simple averaging algorithm (income averaging) to detect discrepancies. Despite mounting evidence of "hallucinated" debts and thousands of errors, senior leadership relied on the system's "Efficiency Dashboards." They treated the algorithm's output as an objective truth that justified aggressive debt recovery without human review. The system was eventually ruled unlawful. A Royal Commission found that officials used the "automation" as a shield to ignore clear warnings from front-line staff.

---

[9] https://www.theguardian.com/australia-news/2026/mar/14/robodebt-report-secret-section-what-does-it-reveal-ntwnfb

In **Mobley v. Workday, Inc[10].**, a job applicant filed a lawsuit alleging that Workday's AI-powered hiring software unfairly screened him out of multiple job opportunities. The plaintiff, Derek Mobley—a Black applicant over 40 with a disability—claimed he was rejected from numerous jobs through companies that used Workday's automated hiring platform. The lawsuit argues that Workday's machine-learning hiring system ranked and filtered candidates in ways that disproportionately excluded older applicants and other protected groups, potentially violating U.S. anti-discrimination laws such as the Age Discrimination in Employment Act (ADEA). In many hiring environments using AI screening tools, Organizations often assume that "The system filtered the candidate." but legally and operationally, the employer remains accountable for the hiring process, even if algorithmic tools are involved. Courts increasingly treat AI systems as agents within organizational decision-making, meaning responsibility cannot simply be transferred to the software vendor or algorithm.

Another scenario Dashboard Certainty vs Contextual Risk, consider a CISO who reports a high secure posture, strong SLA adherence, and AI-prioritized vulnerability triage. Yet, a breach occurs two months later due to a configuration edge case, a unique architectural dependency, or a risk that was deprioritized by the AI model. Post-incident analysis reveals that the vulnerability was not prioritized, local operational nuances were missing from the model, and no executive intervened to override the AI ranking. The resulting question—who is accountable: the model, the vendor, the analyst, or the CISO?—underscores the structural problem created by detachment from decision context.

Root Cause: Decision Context Detachment

"Professional Absolution" arises when execution authority is delegated, risk prioritization is algorithmically generated, decision ownership is not explicitly reaffirmed, and human override responsibility remains ambiguous.

In this setting, the machine becomes the evaluator, prioritization actor, and implicit decision proxy, while governance frameworks still assume that humans exercise final discretion. When this discretion is passive rather than active, accountability becomes detached from execution reality—a phenomenon best described as Decision Context Detachment.

Not all automation results in Absolution Bias. The distinction lies in whether a system merely executes predefined, transparent rules (classic automation) or applies model inferences that produce probabilistic, often opaque rankings (delegated judgment). When human oversight becomes passive and contextual overrides are rarely exercised, the likelihood of Absolution Bias grows.

Governance Countermeasure: The Accountability Anchor Model

To prevent accountability diffusion, agentic systems must be integrated into decision-right structures.

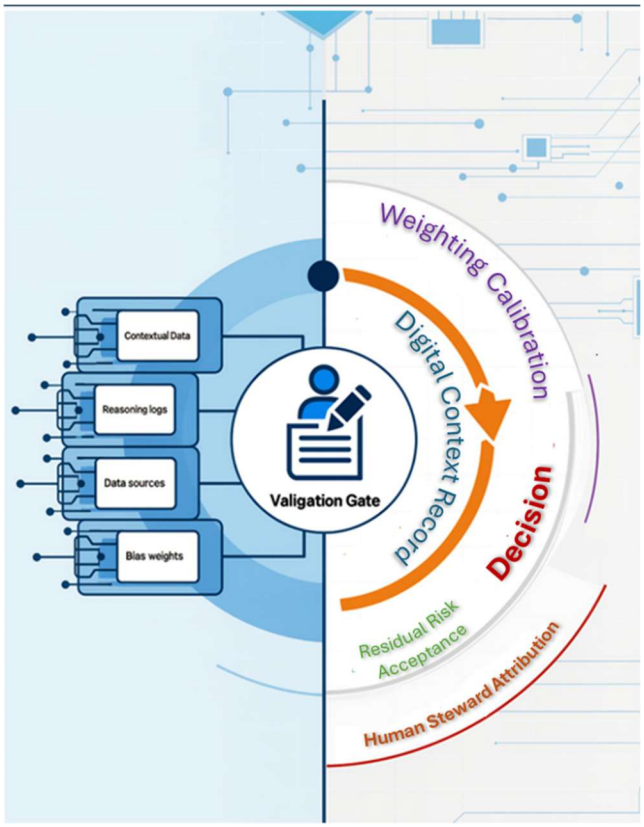
This requires three explicit mechanisms:

---

[10] https://www.callaborlaw.com/blog/federal-court-grants-preliminary-certification-in-landmark-ai-hiring-bias-case

- Attribution Clarity that Distinct machine identity, Logged execution traces and Clear separation from human credentials
- Mandate Documentation which defines scope of authority, Explicit boundaries of autonomous action, and formal risk acceptance for automated pathways
- Decision Context Record (DCR) is for material decisions influenced by AI: Why was the ranking accepted? What local risk appetite factors were considered? Was contextual override evaluated?

At the governance level, it establishes a new principle: AI-generated metrics cannot replace executive judgment. These metrics must be calibrated to local risk appetite, contextualized within the organization's architectural reality, and actively validated by accountable roles. Accountability cannot be algorithmically outsourced; if delegated execution exists, accountability must be explicitly re-anchored to responsible human actors.



Professional Absolution is not misconduct but a structural drift caused by increasing autonomy, growing algorithmic influence, and static governance assumptions. If Section I identifies delegated authority, Section II restores decision ownership. Without it, governance risks becoming performative rather than authoritative.

A DCR does not require extensive documentation but should include enough information to demonstrate accountable decision-making. This minimal record preserves the human judgment layer, ensuring that AI outputs do not replace accountable decision-making.

Table 2:Minimum Content of a DCR

DCR Element	Purpose
Decision Identifier	Links the decision to a ticket, change request, or risk record
AI System Involved	Identifies the AI tool, model, or agent influencing the decision
AI Recommendation	Summary of the AI-generated output or ranking
Human Evaluation	Explanation of how the recommendation was validated or overridden
Risk Context	Reference to applicable risk appetite, severity level, or operational impact
Decision Owner	Accountable individual approving the final decision
Outcome	Accepted, modified, or rejected recommendation
Timestamp	Date of decision and approval

Mapping Accountability Reinforcement to Existing Frameworks

While "Professional Absolution" describes a governance drift phenomenon, accountability reinforcement is not new. It is already embedded within established standards — but often not applied explicitly to AI-driven decision pathways.

While standards like ISO/IEC 27001, ISO/IEC 42001, NIST SP 800-37, and the NIST AI Risk Management Framework (AI RMF) all explicitly recognize the importance of leadership, role clarity, and documented accountability, they do not always address the unique challenges posed by agentic AI systems. In particular, these frameworks often assume that risk decisions and executive authority remain firmly in human hands, but do not provide explicit mechanisms for maintaining this when AI influences prioritization or risk ranking.

For example, ISO/IEC 27001 expects management to remain accountable for information security decisions, but without reinforcement, AI-driven recommendations could inadvertently bypass required management review. Similarly, ISO/IEC 42001 brings accountability into the AI lifecycle yet focuses on ethical governance and risk transparency, not on re-anchoring authority when AI shapes operational priorities. The NIST RMF and AI RMF both emphasize conscious, executive risk acceptance and clear accountability, but may be undermined if AI-generated metrics are accepted passively or without proper contextual override.

Also, Authority Drift does not represent failure of ISO or NIST frameworks. Rather, it represents a mismatch between static governance assumptions and evolving execution reality. Agentic AI environments risk undermining these assumptions unless explicitly reinforced.

In this Section, we address these gaps by explicitly requiring documentation of AI's influence on material decisions, reaffirming executive ownership through mechanisms like Decision Context Records, and ensuring that responsibility is not displaced by automated processes. This reinforcement transforms AI oversight from merely model-centric to authority-centric, ensuring that human accountability is preserved, and that the adoption of AI strengthens rather than weakens organizational governance.

Section III — Technology Controls for Runtime Governance of Agentic AI

From Governance Principles to Runtime Controls

Sections I and II addressed the governance foundations of agentic systems: identifying delegated authority and ensuring accountability remains anchored to human decision-makers. However, once an AI system begins executing actions within an operational environment, governance must translate into technical enforcement mechanisms.

Agentic systems operate through dynamic reasoning loops that include retrieval, planning, tool invocation, and action execution. This means authority is exercised not through static configuration but through runtime decision processes.

Therefore, security controls must focus on execution boundaries, identity isolation, tool governance, and runtime observability. Current platforms (e.g., Claude Code) demonstrate the implementation of some required authority controls, such as Tool permission loops, OS sandboxing, Human-in-the-loop gating, Scoped directory access.

Not all controls must be implemented simultaneously. Organizations typically mature their agentic AI governance in stages aligned with risk exposure. This maturity model allows organizations to incrementally implement agentic governance controls while maintaining operational velocity.

Phase	Primary Objective	Key Controls
Phase 1 — Identification	Establish visibility of agentic systems	Delegated Authority Classification, Agent Identity
Phase 2 — Boundary Control	Define operational limits	MEP definitions, least privilege, tool allowlists
Phase 3 — Human Oversight	Prevent uncontrolled actions	Permission-first execution, human approval gates
Phase 4 — Runtime Monitoring	Detect abnormal agent behavior	Telemetry collection, anomaly detection
Phase 5 — Incident Response	Respond to agent malfunction or misuse	Kill-switch capability, runtime deactivation
Phase 6 — Continuous Governance	Integrate AI into enterprise risk management	KPI monitoring, governance review cycles

The section below summarizes the current technology control best practices

3.1 Identity and Credential Isolation for AI Agents

One of the most widely recognized best practices in agentic system security is the use of dedicated machine identities for autonomous systems.

Agentic systems should never inherit human credentials or operate under shared service accounts. Instead, each agent should be assigned a synthetic machine identity with scoped privileges and full audit traceability.

Key implementation patterns include:

- Dedicated service accounts or machine identities
- Strict least-privilege access policies
- Credential isolation from human operators
- Hardware-backed or short-lived credentials where possible
- Complete attribution of all agent actions to a unique identity

This approach ensures non-repudiation, traceability, and revocation capability, aligning with best practices in identity and access management.

3.2 Tool Invocation Governance

Modern agentic architectures interact with external systems through tool interfaces, such as APIs, shell commands, databases, or orchestration frameworks.

Because tool invocation is the primary mechanism through which an agent influences the external environment, it becomes a critical control surface.

Best practices include:

- Explicit allowlists of permitted tools
- Risk classification of tool actions
- Enforcement of execution policies outside the model
- Sandboxed tool environments
- Command validation before execution

Many modern agent frameworks follow this pattern, where the model proposes an action but the runtime environment decides whether execution is allowed.

This separation between cognitive reasoning and operational execution is a fundamental design principle for safe agent deployment.

3.3 Policy-Driven Runtime Enforcement

To prevent uncontrolled execution, agent environments increasingly rely on policy-as-code enforcement layers.

These policy layers evaluate whether a proposed action complies with organizational rules before allowing execution.

Common implementations include:

- policy engines controlling agent actions
- infrastructure guardrails
- admission controllers in container platforms
- runtime authorization checks
- conditional execution approval workflows
- Policy-driven enforcement ensures that organizational governance policies are translated into machine-enforceable rules.

3.4 Human-in-the-Loop Oversight

For actions with significant operational impact, many agent systems incorporate human approval gates.

In these workflows, the agent generates an execution plan describing the intended actions, and the plan must be reviewed before execution.

Examples include developer agents that pause before committing code changes or infrastructure agents that require approval before modifying system configuration.

Human-in-the-loop controls provide:

- oversight for high-risk actions
- validation of agent reasoning
- prevention of cascading errors

- alignment with organizational change-management processes

However, excessive reliance on manual approval may limit scalability. Therefore, approval gates are typically reserved for state-changing or high-risk operations.

3.5 Environment Isolation and Execution Sandboxing

Another widely adopted control mechanism is runtime isolation. Agents should operate inside controlled execution environments that limit their ability to access external systems or modify critical resources.

Typical isolation mechanisms include:

- containerized execution environments
- filesystem sandboxing
- network segmentation
- restricted environment variables
- ephemeral runtime instances

These controls reduce the potential blast radius of agent errors or compromise.

3.6 Observability and Auditability

Agentic systems introduce complex execution paths that may involve multiple reasoning iterations, tool invocations, and data retrieval steps.

To maintain governance visibility, systems should maintain comprehensive execution telemetry.

Important logging elements include agent identity, task objectives, reasoning plans, tool invocations, execution outcomes and approval decisions. This telemetry supports forensic investigation, compliance reporting, risk monitoring and governance review

Without detailed observability, organizations cannot reconstruct or audit agent actions.

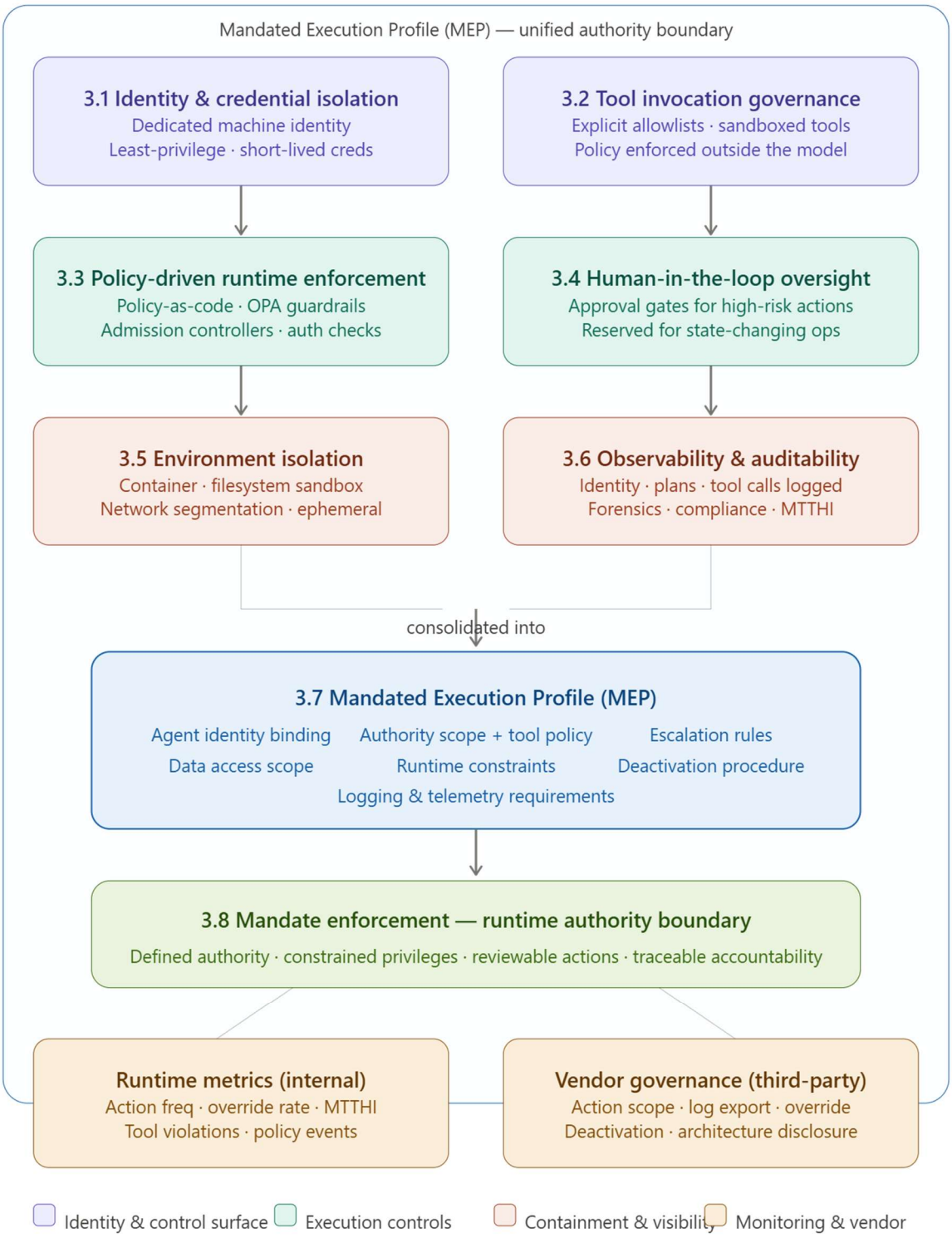
While the controls above are widely recognized best practices, they are often implemented independently and without a unified governance model.

To address this fragmentation, we propose that organizations can define Mandated Execution Profiles (MEPs) that consolidate runtime authority controls into a structured framework.

A mandate, in this context, describes the foundational elements that establish and govern the authority of AI agents within an organization. Rather than a collection of technical controls, a mandate weaves together identity, authority, and operational boundaries into a unified governance structure.

A core aspect of this mandate is the assignment of distinct machine identities to each agent. These identities are tightly bound to specific action thresholds, meaning that before an agent is allowed to perform high-privilege or sensitive actions, a human review or "drill-down" is required. This ensures that critical decisions or escalations are not left solely to autonomous processes but instead involve explicit human oversight.

The runtime controls described in this section align with the NIST AI Risk Management Framework MANAGE function, particularly MG-2 and MG-3, which require organizations to monitor AI systems during operation and maintain the capability to respond to AI-related incidents. Mandated Execution Profiles, runtime telemetry, and agent deactivation procedures provide the operational mechanisms necessary to demonstrate these controls in practice.



3.7 Mandated Execution Profiles (MEP)

To ensure consistent implementation of delegated authority controls, organizations should define a Mandated Execution Profile (MEP) for each AI agent operating with execution authority. The MEP serves as the operational contract governing how an agent may interact with enterprise systems.

Existing controls in AI agent might include IAM / workload identity, policy-as-code or approval workflow. A MEP is not a replacement but a governance wrapper that binds them to an AI agent's delegated mandate.

More specifically:

- **Workload identity governance** answers: *who is the workload?*
- **Policy-as-code** answers: *what infrastructure rules are enforced?*
- **MEP** answers: *what actions is this AI agent authorized to initiate, under what mandate, with what escalation rules?*

So MEP is the **agent-specific authority contract**, while policy-as-code and workload identity are control mechanisms that implement parts of that contract.

The purpose of the MEP is not to describe the AI model itself, but to define the runtime boundaries under which the agent is permitted to operate.

Mandated Execution Profiles are not intended to introduce a parallel governance model. Instead, they act as a **binding layer that translates existing governance controls into enforceable runtime constraints for AI agents**.

In practice, MEPs operationalize established control mechanisms, including:

• **Privileged access management (PAM)** — defining what elevated actions an AI agent may execute
• **Change management processes** — enforcing approval gates, change windows, and rollback requirements
• **Segregation of duties (SoD)** — ensuring that AI agents cannot independently complete conflicting control steps
• **Runbooks and operational procedures** — translating predefined human workflows into constrained execution paths

Rather than replacing these controls, MEPs ensure that **AI agents operate within the same governance boundaries as human operators**, with execution authority explicitly defined, auditable, and enforceable.

A sample MEP structure is as below

MEP Element	Description	Governance Objective
Agent Identity	Synthetic machine identity assigned to the AI agent	Ensures attribution and traceability
Authority Scope	Actions the agent is permitted to perform (read, analyze, modify, execute)	Defines delegated authority boundaries
Tool Invocation Policy	List of permitted tools and APIs the agent may invoke	Limits capability expansion
Decision Escalation Rules	Conditions requiring human approval (permission-first loop)	Prevents uncontrolled automation
Data Access Scope	Datasets and environments the agent may access	Enforces least privilege

Runtime Constraints	Sandboxing, network restrictions, resource limits	Prevents lateral impact
Logging & Telemetry	Required audit logs and runtime telemetry outputs	Enables monitoring and incident investigation
Deactivation Procedure	Mechanism for terminating agent authority	Supports AI incident response

The MEP should be stored within security architecture documentation or AI governance registries and referenced by IAM policy definitions or infrastructure-as-code controls.

3.8 Mandate Enforcement as a Runtime Authority Boundary

When implemented effectively, Mandated Execution Profiles create a runtime authority boundary for agentic systems.

This boundary ensures that:

- delegated authority is explicitly defined
- execution privileges are constrained
- high-impact actions remain reviewable
- accountability remains traceable

Runtime telemetry must support **operational monitoring, governance review, and incident investigation**. These metrics support governance reviews and align with NIST AI RMF MANAGE requirements for operational monitoring and response readiness.

Recommended metrics include:

Metric	Governance Purpose
Agent Action Frequency	Detect abnormal or runaway execution patterns
Human Override Rate	Indicates whether agents are operating within acceptable boundaries
Unauthorized Tool Invocation Attempts	Signals possible prompt injection or privilege escalation
Mean Time to Human Intervention (MTTHI)	Measures effectiveness of escalation controls
Agent Runtime Failures	Identifies stability and safety issues
Policy Violation Events	Indicates attempted authority boundary violations

Many enterprise deployments involve vendor-managed agentic systems where the organization does not control the runtime environment.

In such cases, governance must shift from runtime enforcement to contractual and interface-level controls.

Organizations should require vendors to provide:

Vendor Control Requirement	Governance Objective

Documented agent action scope	Defines delegated authority boundaries
Runtime logging access or export	Enables enterprise monitoring
Human override mechanisms	Allows intervention during critical operations
Agent deactivation capability	Enables incident response
Security architecture disclosure	Supports risk assessment

Together, these mechanisms enable organizations to deploy agentic AI systems while maintaining clear authority boundaries and enforceable governance structures.

Conclusion: The Path Toward Accountable Agency

Along with the adoption of AI technologies, the nature of risk has fundamentally shifted from Output Accuracy to Execution Accountability. Traditional frameworks like the NIST AI RMF provide a vital baseline, but they must be reinforced with specific mechanisms—Synthetic Identities, Mandated Execution Profiles (MEPs), and Decision Context Records (DCRs)—to prevent the emergence of Authority Drift and Professional Absolution.

By integrating these controls into the Agentic AI Security Scoping Matrix and MAAIS layers, technology leaders can move beyond "Dashboard Theater" and ensure that every autonomous action remains anchored to a human mandate. The goal of AI governance is not to slow down innovation, but to provide the structural "Human Anchor" required to scale AI safely and with full professional integrity.

Disclaimer and Professional Disclosures

1. Professional Independence

This white paper is the result of independent research and academic inquiry conducted by the author. The perspectives, frameworks, and recommendations expressed herein are solely those of the author and do not represent the official views, strategies, or endorsements of any current or former employers, clients, or affiliated organizations. This paper proposes a working governance model for agentic AI environments. I welcome peer review and discussion from CISOs, security architects, and AI governance practitioners.

2. Acknowledgment of Known Challenges

The author acknowledges that the field of Agentic AI Security is rapidly evolving and contains significant implementation hurdles:

Interoperability: Standardized protocols for "Cognitive Brakes" and cross-platform Mandated Execution Profiles (MEPs) are not yet universally supported by all LLM providers.

Administrative Overhead: The implementation of Decision Context Records (DCRs) requires a cultural shift in leadership that may initially impact operational velocity in high-speed environments.

Identity Maturity: Managing thousands of distinct "Synthetic Machine Identities" requires a high level of IAM maturity that many enterprises are still developing.

3. Disclosure of Generative AI Assistance

The strategic frameworks, root-cause analysis (Identity/Absolution), and professional critiques in this paper are the original work of the author, informed by the $(ISC)^2$ Strategic AI Strategy curriculum.

Generative AI was utilized as a structural assistant to synthesize these field observations